

Clase 314 — Federación, SSO, SAML y OpenID Connect

Parte: **17 — Profundización para certificaciones** · Fuente: (ISC)² CISSP Official Study Guide — Dominio 5 · OASIS SAML 2.0 · OpenID Connect Core 1.0  Duración estimada: **100 min** · Nivel: **Avanzado**

Objetivo

Entender cómo las organizaciones permiten a un usuario autenticarse una vez y acceder a múltiples aplicaciones (**SSO**) y cómo se establece confianza entre dominios distintos (**federación**) mediante **SAML 2.0** y **OpenID Connect (OIDC)**. Aprenderás los roles (IdP, SP, RP), el flujo de los tokens, las relaciones de confianza y los riesgos de seguridad asociados, todo desde una perspectiva defensiva y de arquitectura, tal como lo evalúa el dominio IAM de CISSP.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

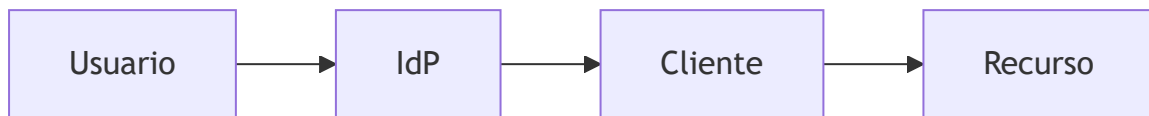
1. **Distinguir** SSO de federación, y autenticación (OIDC) de autorización (OAuth 2.0).
2. **Explicar** el flujo SAML 2.0 SP-initiated con sus roles y aserciones.
3. **Explicar** el flujo Authorization Code de OIDC y el contenido del ID Token (JWT).
4. **Comparar** SAML y OIDC y elegir según el escenario (web empresarial vs. móvil/API).
5. **Identificar** riesgos (robo de aserción, XML Signature Wrapping, phishing de IdP) y mitigaciones.
6. **Diseñar** una relación de confianza federada con sus metadatos y controles.

Temas

#	Tema	Por qué importa
1	SSO vs. federación	Conceptos que suelen confundirse en el examen
2	Roles: IdP, SP, RP	Definen quién autentica y quién confía
3	SAML 2.0 y aserciones	Estándar dominante en SSO empresarial
4	OAuth 2.0 vs. OIDC	Autorización vs. autenticación; base de apps modernas
5	Tokens: aserción SAML, ID Token, access token	Portan la identidad y los permisos
6	Trust y metadatos	La confianza se establece con certificados y URLs
7	Riesgos de federación	Un IdP comprometido compromete todo
8	JIT provisioning y atributos	Cómo se crean cuentas al vuelo con claims

Modelo mental y caso de decisión

Federación separa autenticación, assertion/token, cliente y recurso. Firmar no corrige audiencia, redirect URI o autorización erróneas.



Caso razonado. Un token válido para otra audiencia es aceptado. El recurso valida emisor, audiencia y contexto.

Glosario operativo complementario

Término	Definición
Evidencia	Información cuya procedencia y relación con un criterio pueden revisarse.
Supuesto	Condición declarada de la que depende una conclusión.
Riesgo residual	Exposición que permanece después del tratamiento.

Criterio de dominio

El alumno demuestra dominio cuando explica el diagrama, resuelve el caso con evidencia, declara límites y puede defender por qué su decisión cambia si cambia un supuesto.

Definiciones y características

- **SSO (Single Sign-On):** el usuario se autentica una vez y accede a varias aplicaciones sin volver a introducir credenciales. Característica: mejora UX y reduce fatiga de contraseñas.
- **Federación de identidad:** acuerdo de confianza que permite usar una identidad de un dominio (IdP) para acceder a recursos de otro (SP). Característica: cruza fronteras organizativas.
- **IdP (Identity Provider):** autentica al usuario y emite aserciones/tokens. Es la fuente de la identidad.
- **SP / RP (Service Provider / Relying Party):** la aplicación que confía en el IdP y consume la aserción (SAML) o el token (OIDC) para dar acceso.
- **SAML 2.0:** estándar XML de OASIS para intercambiar aserciones de autenticación, atributos y autorización entre IdP y SP. Predomina en SSO web empresarial.
- **OAuth 2.0:** framework de **autorización** (acceso delegado a recursos mediante access tokens); no autentica por sí mismo. Base sobre la que se construye OIDC.
- **OIDC (OpenID Connect):** capa de **autenticación** sobre OAuth 2.0 que añade el **ID Token** (un JWT firmado con claims de identidad). Predomina en móvil, SPA y APIs.
- **Claim / atributo:** dato sobre el usuario (correo, grupos, roles) transportado en la aserción o el token; alimenta la autorización y el aprovisionamiento JIT.

Herramientas y preparación

- **Keycloak** (open source) como IdP de laboratorio para ver SAML y OIDC en un entorno propio.

- **jwt.io** o la librería que prefieras para **decodificar** (no falsificar) un JWT y leer sus claims (`iss` , `sub` , `aud` , `exp` , `nonce`).
- Un **analizador de tráfico del navegador** (DevTools → Network) para observar redirecciones, el `SAMLRequest` / `SAMLResponse` y el `authorization_code` . Todo sobre servicios propios de prueba.
- Especificaciones de referencia: SAML 2.0 Core (OASIS) y OpenID Connect Core 1.0.

Laboratorio guiado — Trazar flujos y diseñar una confianza federada

Ejercicio de arquitectura y observación; trabaja solo con tu IdP y apps de prueba.

1. **Mapa de actores.** Para "**NovaSalud**", identifica el IdP corporativo y 2 SP/RP (un portal web interno vía SAML y una app móvil vía OIDC). Dibuja quién confía en quién.
2. **Flujo SAML SP-initiated.** Traza los pasos: (1) usuario accede al SP → (2) SP redirige al IdP con un `SAMLRequest` → (3) IdP autentica → (4) IdP devuelve una `SAMLResponse` con la aserción firmada → (5) SP valida la firma y crea la sesión. Anota qué se firma y por qué.
3. **Metadatos y confianza.** Documenta cómo se establece el trust: intercambio de metadatos (EntityID, endpoints ACS/SSO, certificado público de firma). Explica qué pasa si el certificado caduca.
4. **Flujo OIDC Authorization Code.** Traza: authorization request → login en el IdP → `code` → intercambio del `code` por `id_token` + `access_token` en el token endpoint → validación del JWT.
5. **Anatomía del ID Token.** Decodifica un JWT de ejemplo y explica los claims `iss` , `aud` , `sub` , `exp` , `nonce` . Indica qué valida el RP en cada uno para aceptar el token.
6. **SAML vs. OIDC.** Rellena una tabla comparativa: formato (XML vs. JSON/JWT), transporte, idoneidad (web empresarial vs. móvil/API), complejidad y madurez.
7. **Modelo de amenazas.** Enumera riesgos y mitigaciones: robo/replay de aserción (usa `NotOnOrAfter` , `nonce` , TLS), **XML Signature Wrapping** (valida correctamente la firma), IdP comprometido (MFA reforzada, monitorización), phishing de la página del IdP (dominios y avisos claros).
8. **Aprovisionamiento JIT.** Define cómo, al primer login federado, se crea la cuenta local a partir de los claims (correo, grupos → roles RBAC de la clase 313).

Ejercicios

1. Explica con tus palabras por qué OAuth 2.0 solo no debe usarse para "iniciar sesión".
2. Ordena correctamente los pasos desordenados de un flujo SAML SP-initiated.
3. Decodifica un ID Token de ejemplo y explica cada claim estándar.
4. Diseña la tabla comparativa SAML vs. OIDC y recomienda uno para 3 escenarios distintos.
5. Describe el ataque de XML Signature Wrapping a alto nivel y su mitigación defensiva.
6. Dibuja el trust de una federación con 1 IdP y 3 SP e indica qué se comparte con cada uno.

Reto verificable

Entrega un **Diseño de Arquitectura de SSO Federado** para NovaSalud que incluya: diagrama de actores (IdP/SP/RP), los dos flujos (SAML y OIDC) paso a paso, la tabla de metadatos/confianza, un modelo de amenazas con al menos 4 riesgos y mitigaciones, y la regla de aprovisionamiento JIT.

Criterio de aceptación: un arquitecto que reciba tu diseño puede explicar, sin ayuda, qué sistema autentica, qué token viaja en cada flujo, qué se valida para aceptarlo y cómo se mitiga el robo de aserción/token.

⚠ Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Usar OAuth 2.0 "para login" y confiar el access token como identidad	OAuth autoriza, no autentica. Usa OIDC y valida el ID Token .
<code>Invalid signature</code> en la SAMLResponse	Certificado de firma incorrecto o caducado en los metadatos. Rota y actualiza los metadatos del SP.
ID Token aceptado sin validar <code>aud / iss / exp</code>	Permite tokens de otro cliente o expirados. Valida siempre todos los claims.
SSO habilitado sin MFA en el IdP	El IdP se vuelve un único punto de fallo. Refuerza el IdP con MFA fuerte.
Reutilizar el mismo <code>RelayState</code> / sin <code>nonce</code>	Expone a replay/CSRF. Usa <code>nonce</code> / <code>state</code> de un solo uso y TLS.
Aprovisionar JIT sin filtrar claims	Se crean cuentas con roles indebidos. Mapea claims a roles con reglas explícitas.

? Preguntas frecuentes

? **¿SAML o OIDC para una nueva aplicación?** Para web empresarial con muchos SP legados, SAML sigue siendo común. Para móvil, SPA y APIs, OIDC (JSON/JWT, más ligero) es la elección moderna. Muchas organizaciones soportan ambos en su IdP.

? **¿La federación aumenta o reduce el riesgo?** Ambos. Reduce contraseñas dispersas y centraliza la política, pero concentra el riesgo en el IdP: si cae o es comprometido, afecta a todo. Por eso el IdP exige MFA fuerte y monitorización.

? **¿Qué diferencia hay entre un access token y un ID token?** El **access token** autoriza el acceso a un recurso/API (OAuth); el **ID token** prueba la identidad del usuario al cliente (OIDC). No uses el access token como prueba de identidad.

? **¿Qué es el XML Signature Wrapping?** Una familia de ataques que manipula la estructura XML para que el SP valide una firma legítima pero procese contenido malicioso. La defensa es una validación estricta de la firma y la referencia.

🔗 Referencias

- OASIS — *Security Assertion Markup Language (SAML) v2.0*. <https://docs.oasis-open.org/security/saml/v2.0/>
- OpenID Foundation — *OpenID Connect Core 1.0*. https://openid.net/specs/openid-connect-core-1_0.html
- RFC 6749 — *The OAuth 2.0 Authorization Framework*. <https://www.rfc-editor.org/rfc/rfc6749>
- (ISC)² — *CISSP Official Study Guide*, 9.^a ed., Dominio 5 IAM (federación y SSO).
- OWASP — *SAML Security Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/SAML_Security_Cheat_Sheet.html



Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.



Clase anterior

[Clase 313 — Gestión del ciclo de vida de identidades \(IAM empresarial\)](#)



Siguiente clase

[Clase 315 — MFA y gestión de accesos privilegiados \(PAM\)](#)